

Project Background

Operational Technology (OT) controls critical systems across various industries, including manufacturing, healthcare, and transportation.

Programmable Logic Controllers (PLCs) manage complex operations and are designed for speed and reliability.

Because PLCs communicate over industrial protocols such as **EtherNet/IP (CIP)**, often operating on trusted internal networks without built-in security mechanisms. Resulting in systems that are vulnerable to **unauthorized access, traffic interception, and command manipulation**.

Problem Statement

PLCs control critical physical systems, where unauthorized access or device failure can directly compromise safety and operational uptime.

Despite often being placed on isolated networks, many PLCs lack strong built-in cybersecurity protections and may still be vulnerable to network-based attacks. This project evaluates how a PLC communicates over a network and whether control variables can be accessed or modified through external interaction.

The goal is to identify **potential security risks** and better understand the **cybersecurity considerations** of PLC systems.

Goals and Objectives

The project aims to assess the impact of weak cybersecurity practices in PLC systems by:

- **Identifying vulnerabilities** in PLC communication and architecture
- **Analyzing EtherNet/IP (CIP) traffic** between workstation and PLC
- **Testing read/write access** to control variables during runtime
- **Simulating real-world attacks** (MITM, command injection)
- **Improving testing efficiency** using automated tools.

Design Requirements

This project focuses on testing a pre-configured PLC system in a controlled lab environment to simulate a real-world PLC setup, identifying vulnerabilities, and observing system behaviors.

Key requirements include:

- Analyzing PLC communication
- Testing read/write access to control variables, simulating attack scenarios
- Observing physical input behavior, and assessing system robustness

Methodology

Testing focused on **three layers**:

PLC Layer:

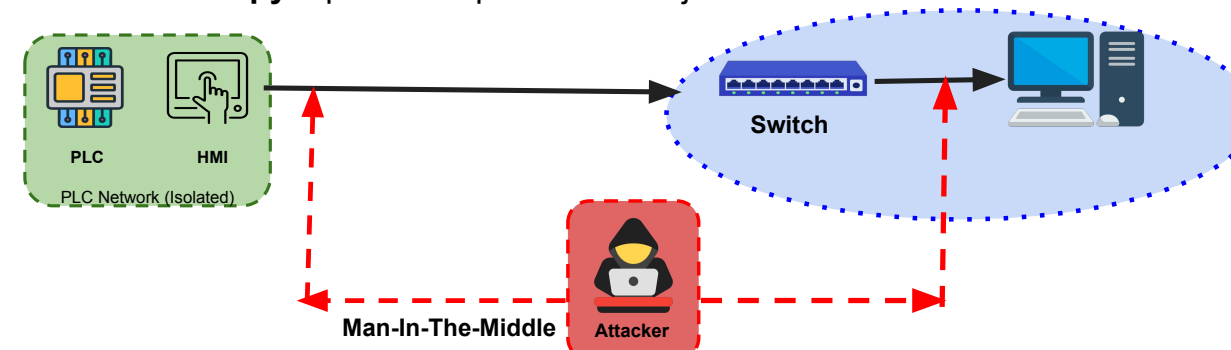
- Firmware and ladder logic execution
- Runtime variable manipulation

Network Layer:

- EtherNet/IP (CIP) communication over **TCP port 44818**
- Packet capture and protocol analysis

Attack Surface:

- External attacker system (Kali Linux)
- Tools used:
 - **Kali Linux** - OS for penetration testing and cybersecurity analysis
 - **Wireshark** – packet capture and analysis
 - **Pylogix / Pycomm3** – PLC communication
 - **Ettcap** – ARP spoofing (MITM)
 - **Scapy** – packet inspection and injection



Project Mentors

Thank you, Disney Team!
Joshua Womack, Alexander
Graham, Joe Benson, Han
Nguyen, Hayley Yukihiro

Dr. Mikhail Gofman,
Prof. Michael Franklin
Center for Cybersecurity
Cal State Fullerton

Results and Outcomes

The team developed a PLC security testing framework to evaluate vulnerabilities across the network and control surfaces. Testing revealed that communication between the workstation and the PLC occurs in cleartext, allowing control commands and data to be easily captured and analyzed.

Identified vulnerabilities in: **Network Surface, Control Surface, Firmware / CCW**

Demonstrated attacks: **MITM (ARP Spoofing), Command Injection**
Overrode PLC behavior in real time: **Modified control variables**

Confirmed, **no authentication or access control**:

- Unauthorized Access
- Read/write required no credentials

Additional risks were identified at the **Firmware/CCW level**:

- Possible to access/extract PLC Logic

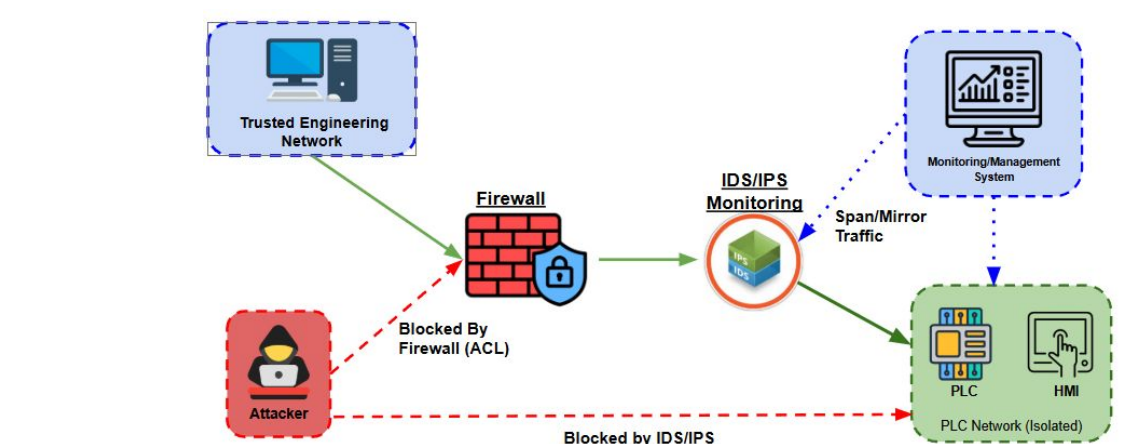
Demonstrated Security Risks:

- Unauthorized Access, Loss of Integrity, Data Exposure

Summary

The team developed a PLC security testing framework and identified vulnerabilities across the network, control, and firmware layers. Testing demonstrated attacks such as Man-in-the-Middle (MITM) using ARP spoofing and command injection, showing that PLC behavior can be manipulated in real time without **authentication**.

Future Directions



- **Firewall / ACL rules** to restrict PLC access to trusted devices
- **VLAN segmentation** to isolate PLCs from unauthorized networks
- **IDS/IPS monitoring** to detect and block malicious traffic in real-time